



HACK THE BOX · LINUX

Lame

Informe tècnic complet ·
cas RETRO documentat

Màquina Lame resolta

HTB Lame · 2025-05

Autor	Ramon Santos Sabarich / r4ms4nt
Tipus	Informe tècnic complet i arxivable
Objectiu	Documentar enumeració, CVE, user i root amb traçabilitat clara i reutilitzable
Data	2025-05



Informe tècnic normalitzat per a arxivament, consulta i traçabilitat.

GUIA DE LECTURA

Índex

Informe tècnic final en català, maquetat per a arxiu, estudi i consulta. Es conserva la cadena real del cas, es distingeixen els passos verificats i es manté visible el punt que continua pendent de verificar.

- 1. Introducció del cas
- 2. Fonts utilitzades i criteri editorial
- 3. Preparació i arrencada del cas
- 4. Enumeració inicial
- 5. Identificació de la primera superfície dominant: VSFTPD
- 6. Validació de la línia VSFTPD: prova, resultat i descart
- 7. Enumeració de Samba i selecció de la via principal
- 8. Explotació validada mitjançant CVE-2007-2447
- 9. Obtenció de user.txt
- 10. Obtenció de root.txt
- 11. Observacions tècniques complementàries
- 12. Resum tècnic final de la cadena real
- 13. Lliçons reutilitzables per a PENTEST-STUDIO

Cadena tècnica validada

Enumeració inicial breu.

VSFTPD 2.3.4 identificat i provat sense sessió útil.

Samba 3.0.20 associat a CVE-2007-2447 com a via principal.

Shell útil obtinguda com a root.

Lectura posterior de user.txt i root.txt des de context privilegiat.

1. Introducció del cas

Lame és una màquina retirada de **Hack The Box** reconstruïda aquí com a cas **RETRO** dins de **PENTEST-STUDIO**. L'objectiu d'aquest document no és simular una resolució nova ni embellir artificialment l'explotació, sinó convertir el material conservat en un informe d'estudi sòlid, fidel i reutilitzable.

La cadena tècnica que sí queda validada per l'evidència disponible és senzilla, però molt útil des del punt de vista formatiu:

- enumeració inicial breu;
- detecció de dues línies potencialment vulnerables;
- descart d'una via famosa però no productiva;
- canvi de focus cap a un servei llegat més explotable;
- obtenció directa de context `root`;
- lectura de `user.txt` i `root.txt` ja des d'aquest context privilegiat.

Aquest cas ensenya una cosa important: una màquina senzilla no ha de produir necessàriament una documentació pobre. Precisament perquè la cadena és curta, convé deixar molt ben explicats els motius de cada decisió, què es va observar realment i quina part del cas queda pendent de verificar amb més precisió.

2. Fonts utilitzades i criteri editorial

Fonts de partida

Aquest Markdown s'ha reconstruït a partir d'aquestes peces conservades dins del cas:

- el **PDF final net** de la màquina;
- el contingut tècnic principal ja reorganitzat en aquell PDF;
- l'**annex històric** que preserva el Markdown antic del cas;
- l'evidència visual històrica integrada en el mateix document.

Criteri editorial aplicat

Per construir aquesta versió final s'han seguit aquestes regles:

- no inventar passos no sostinguts pel material disponible;
- mantenir separats els **fets verificats**, les **inferències raonables** i els **punts pendents de verificar**;
- convertir un cas operatiu curt en un document didàctic útil per a l'estudi posterior;
- conservar ordres, flags, decisions i pivots reals sempre que la font els preservi;
- no omplir amb memòria o amb una explotació "més bonica" els buits que la font no documenta;
- mantenir al final del document un bloc de **traçabilitat** amb les notes històriques conservades.

Nota de precisió important

Des del principi convé fixar quatre matisos per evitar males lectures del cas:

1. La línia **VSFTPD 2.3.4** va ser **enumerada i provada**, però no va ser la via útil de resolució documentada.
2. La línia **Samba 3.0.20 / CVE-2007-2447** sí que queda **validada** com a explotació exitosa.
3. El material conservat valida que la shell útil resultant correspon a `root`, de manera que la lectura de totes dues flags es fa ja des d'un context privilegiat.

4. La **sintaxi exacta de l'exploit de Samba** no queda preservada textualment en l'evidència disponible. El resultat sí que està validat, però aquest detall s'ha de mantenir com a **pendent de verificar**.

3. Preparació i arrencada del cas

Com que és un cas RETRO, la fase de preparació no consisteix a reconstruir un entorn des de zero, sinó a llegir el cas com si s'estigués revisant un registre tècnic històric. Això canvia l'enfocament documental:

- no es descriu una sessió nova de laboratori;
- no s'afegeix instrumentació que no aparegui a les fonts;
- no es reescriu l'explotació com si s'hagués fet avui amb una altra metodologia;
- es treballa sobre la **cadena real observada**.

Per això, en aquest document cada fase respon a una pregunta concreta:

- què va quedar realment observat?
- per què aquell pas tenia sentit?
- quina lectura tècnica es va fer del resultat?
- què va canviar a partir d'aquí?

Aquest enfocament permet transformar notes d'explotació o material històric en un document d'aprenentatge molt més útil que una simple llista d'ordres.

4. Enumeració inicial

Què es va fer

L'enumeració inicial parteix d'un escaneig dels **1000 ports TCP més comuns** seguit d'un filtratge dels ports oberts:

```
nmap -v -T4 -Pn --top-ports 1000 -oA nmap/top1000_tcp 10.129.56.2  
grep open nmap/top1000_tcp.nmap
```

Per què aquest pas tenia sentit

En una màquina senzilla o d'inici, un escaneig dels ports més comuns sol ser suficient per identificar la major part de la superfície explotable sense entrar encara en un escombratge complet de 65535 ports. Aquí l'objectiu no era esgotar totes les possibilitats des del primer minut, sinó obtenir una **lectura ràpida dels serveis dominants**.

L'ordre emprada combina diverses decisions útils:

- `-v` augmenta la verbatim per seguir el progrés de l'escaneig;
- `-T4` accelera el ritme sense ser una agressivitat extrema;
- `-Pn` evita dependre del ping inicial;
- `--top-ports 1000` prioritza la superfície més probable;
- `-oA` desa la sortida en diversos formats per poder revisar-la després;
- `grep open` simplifica la lectura final i deixa només els serveis rellevants.

Què es va observar realment

El resultat verificat va ser aquest:

- 21/tcp
- 22/tcp
- 139/tcp
- 445/tcp

Total de ports oberts en aquesta fase: **4**.

Com s'interpreta la troballa

Aquest primer resultat ja organitza la màquina en tres línies principals:

- **FTP** a 21/tcp
- **SSH** a 22/tcp
- **SMB / NetBIOS** a 139/tcp i 445/tcp

No totes aquestes línies mereixen el mateix pes documental.

L'evidència conservada desenvolupa de debò dues branques:

- la línia **FTP**, perquè existeix una versió vulnerable coneguda que calia comprovar;
- la línia **Samba**, perquè finalment és la via que sí que condueix a l'explotació vàlida.

22/tcp queda visible i no s'ha d'esborrar, però tampoc convé sobredimensionar-lo: en el material disponible **no apareix com a via explotada ni com a pivot útil**.

Què canvia després

Un cop vista la superfície, la decisió lògica següent és **identificar versions** en els serveis més prometedors. Donat l'historial conegut de **vsFTPD 2.3.4** i la rellevància clàssica de Samba antic a HTB, el cas avança de manera natural cap a aquestes dues branques.

Lliçó reutilitzable

L'enumeració inicial no consisteix només a "veure ports". El seu valor real és **jerarquitzar línies d'investigació**. En aquest cas, això evita dos errors freqüents:

- perdre temps en un servei visible que no està sostingut per l'evidència del cas;
- saltar massa aviat a una explotació sense confirmar abans la versió real del servei.

5. Identificació de la primera superfície dominant: VSFTPD

Detecció de versió

Per confirmar la identitat del servei FTP es va executar:

```
nmap -sV -p21 -oA nmap/ftp_version 10.129.56.2
```

Què busca aquesta ordre

En aquest punt ja no interessa saber si el port està obert —això ja va quedar validat a la fase anterior—, sinó **quina versió concreta** del servei respon a 21/tcp.

Aquí -sV és la peça clau, perquè permet passar d'una intuïció genèrica ("hi ha FTP") a una hipòtesi tècnica molt més precisa ("hi ha una versió concreta potencialment vulnerable"). L'escaneig es limita al port 21 perquè l'objectiu ja és quirúrgic: confirmar la versió del servei FTP i decidir si mereix una prova d'explotació.

Què es va observar realment

El servei detectat va ser:

- vsFTPD 2.3.4

Per què aquesta troballa importa

vsFTPD 2.3.4 és una versió molt coneguda per la seva associació històrica amb una backdoor. Quan apareix en una màquina de laboratori, no seria raonable ignorar-la. Però aquí convé recordar una regla metodològica important:

una versió aparentment vulnerable no equival automàticament a una via vàlida de resolució.

La detecció de la versió justifica provar aquesta línia, però encara no la valida com la cadena principal del cas.

6. Validació de la línia VSFTPD: prova, resultat i descart

Què es va executar

La seqüència conservada per provar la via de VSFTPD va ser aquesta:

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 10.129.56.2
run
```

Per què tenia sentit utilitzar aquesta via en aquest moment

Un cop identificada la versió 2.3.4, el més raonable era comprovar si la backdoor associada continuava sent explotable a la màquina. Aquí la prova no apareix com un salt impulsu a Metasploit, sinó com una **validació d'hipòtesi**:

1. el port 21/tcp està obert;
2. el servei és vsFTPD 2.3.4;
3. existeix una explotació històrica associada;
4. per tant, la línia mereix una comprovació directa.

Què fa exactament la seqüència

- msfconsole obre l'entorn d'explotació.
- use exploit/unix/ftp/vsftpd_234_backdoor carrega el mòdul específic per a aquesta vulnerabilitat.
- set RHOSTS 10.129.56.2 defineix l'objectiu.
- run llança la prova.

Què es va observar realment

El material històric deixa validat això:

- l'exploit **s'executa**;
- però **no retorna cap sessió útil**.

Com s'ha de llegir aquest resultat

Aquest és un dels punts més didàctics del cas. La línia no s'ha de descriure com a "fallida" en sentit absolut, ni tampoc com "la màquina era per aquí però alguna cosa va sortir malament". La lectura prudent és més precisa:

- la línia **va ser provada**;
- la prova **no va produir l'accés útil documentat**;
- per tant, la branca **no pot tractar-se com a via principal de resolució**.

Això és important perquè moltes narratives pobres converteixen una versió famosa en la història central del cas encara que l'evidència digui una altra cosa. Aquí no s'ha de fer això.

Què va canviar després

El descart pràctic de la via FTP obliga a tornar a la superfície restant amb una mentalitat clara: cal buscar una segona línia més sòlida. Aquesta segona línia serà **Samba**.

Lliçó reutilitzable

Una via coneguda no es descarta només perquè "sembla vella", ni es manté només perquè "és famosa". Es fa una prova, s'observa el resultat i es decideix sobre la base de l'evidència. Aquesta disciplina és molt més valuosa que memoritzar noms d'exploits.

7. Enumeració de Samba i selecció de la via principal

Què es va executar

La identificació de Samba es va recolzar en aquesta ordre:

```
nmap -sV -Pn -p139,445 --script=smb-protocols,smb-os-discovery,smb2-security-mode,smb2-time
```

Per què aquesta ordre té sentit aquí

Després de comprovar que FTP no produeix cap sessió útil, el següent servei fort de la superfície és SMB a 139/445. En aquest moment no n'hi ha prou amb llançar una prova a cegues: cal **confirmar versió** i obtenir context addicional.

Aquesta ordre no només pregunta "hi ha Samba?", sinó que intenta obtenir una imatge més rica del servei:

- -sV busca la versió concreta;
- -Pn manté el mateix criteri operatiu del cas;
- -p139,445 se centra en els ports propis de SMB / NetBIOS;
- els scripts SMB afegixen context protocol·lari i de descobriment;
- -oA preserva la sortida per a traçabilitat.

Què es va observar realment

La versió detectada va ser:

- Samba 3.0.20

El material històric associa aquesta versió amb:

- CVE-2007-2447

- condició rellevant: ús de `username map script` a `smb.conf`

Què significa aquesta troballa

Aquí és on la màquina deixa de ser una simple successió de proves i passa a tenir una **línia dominant clara**.

La situació queda així:

- FTP ja va ser validat com a **provat però no productiu**;
- Samba apareix amb una versió antiga i amb una vulnerabilitat històrica molt coneguda;
- la font no només menciona la CVE, sinó també la condició tècnica rellevant;
- per tant, la narrativa correcta del cas és que la **via principal passa a ser Samba**.

Inferència raonable

Encara que la sintaxi exacta de l'exploit no es conserva, l'enllaç entre Samba 3.0.20 i CVE-2007-2447 és prou fort per justificar la decisió tècnica de moure el focus cap a aquesta línia. Això no inventa passos: només explica el raonament que encaixa amb l'evidència preservada.

Lliçó reutilitzable

Quan una via prometedora perd força i una altra apareix més sòlida, el canvi de focus ha de quedar escrit com una **decisió tècnica raonada**, no com un salt abrupte. Aquest tipus de pivot és exactament el que convé estudiar i documentar.

8. Explotació validada mitjançant CVE-2007-2447

Fet verificat

La dada central d'aquesta fase és molt clara:

- després d'explotar CVE-2007-2447, la shell obtinguda correspon a `root`.

Què queda demostrat

Encara que no es conserva l'ordre complet d'explotació, sí que queden demostrades tres coses fonamentals:

1. la línia d'explotació efectiva va ser **Samba / CVE-2007-2447**;
2. l'accés útil no acaba en un usuari limitat;
3. el context d'execució passa a ser **directament privilegiat**.

Què no queda conservat

Cal marcar com a **pendent de verificar** aquest detall concret:

- l'**ordre exacta** o la **sintaxi completa** utilitzada per llançar l'explotació de Samba en la resolució històrica.

Això no invalida la cadena del cas. Simplement obliga a documentar-la amb honestedat:

- **resultat validat**;
- **detall d'execució exacte no preservat**.

Per què això importa metodològicament

En màquines fàcils és freqüent caure en un mal hàbit documental: completar buits amb memòria, amb costum o amb la "versió típica" de l'exploit. Aquí no s'ha de fer això. El valor del cas no està a fingir una precisió que no existeix, sinó a ensenyar a distingir entre:

- allò que està **realment validat**;
- allò que és una **lectura raonable**;
- allò que queda **pendent de verificar**.

Què canvia després

Com que la shell vàlida ja és `root`, la narrativa del cas canvia molt respecte de màquines més llargues. No hi ha una fase clàssica de:

- obtenció d'usuari baix;
- enumeració local extensa;
- escalada posterior diferenciada.

Aquí l'explotació útil ja entrega context privilegiat. Per això les fases següents no s'han de maquillar com si hi hagués una escalada llarga que realment no va existir.

Lliçó reutilitzable

Una explotació que acaba directament en `root` obliga a ajustar la manera de narrar el cas. Si es manté una estructura fixa sense pensar, es corre el risc d'inventar una "escalada" que en realitat no va ser una fase separada.

9. Obtenció de user.txt

Què es va executar

La lectura de la flag d'usuari es documenta amb aquesta ruta i aquestes ordres:

```
cd /home/makis  
ls -la  
cat user.txt
```

Per què aquest pas es fa així

Un cop obtingut context privilegiat, la lectura de `user.txt` deixa de ser una maniobra d'accés i passa a ser una **validació de control sobre el sistema**. L'objectiu aquí no és escalar, sinó confirmar que el context assolit permet recórrer el sistema i accedir a les rutes rellevants.

Què fa cada ordre

- `cd /home/makis` situa la sessió al directori de l'usuari;
- `ls -la` permet veure fitxers, permisos i contingut ocult;
- `cat user.txt` mostra la flag.

Què es va observar realment

La flag verificada va ser:

- `60fc5d64febbdebfe8cc331838bfff0b0`

Nota de precisió

Encara que el document conserva aquesta part com a "obtenció de `user.txt`", convé explicar-ho amb claredat:

- no representa una fase independent de privilegis baixos;
- no és l'evidència d'una shell d'usuari limitada;
- és una lectura realitzada **després** que l'explotació vàlida ja hagués entregat context `root`.

Què ensenya aquesta fase

En un writeup mecànic seria fàcil escriure "user" i fer pensar que aquí acaba una primera meitat del cas. Aquí això seria enganyós. La lectura correcta és que `user.txt` forma part del **post-accés privilegiat**, no d'una fase separada de conquesta d'usuari.

10. Obtenció de `root.txt`

Què es va executar

La lectura de la flag final es documenta amb:

```
cd /root
ls -la
cat root.txt
```

Per què aquest pas té valor documental

Encara que el context ja és privilegiat, convé deixar aquesta fase documentada de manera explícita per dos motius:

1. tanca formalment la resolució del cas;
2. confirma que l'accés privilegiat no era aparent ni parcial, sinó suficient per assolir la ruta clàssica d'administració.

Què es va observar realment

La flag verificada va ser:

- `c80b43503b56dc7b0dc82643157b4329r4ms4nt`

Com s'ha d'interpretar

Amb la lectura de `root.txt` queda tancada la cadena documentada. A partir d'aquí ja no hi ha una escalada addicional a explicar, sinó observacions complementàries sobre el comportament d'alguns serveis i sobre el valor metodològic del cas.

11. Observacions tècniques complementàries

Aquesta fase no forma part de la via principal d'accés, però sí que conserva senyals útils que mereixen quedar explicades.

11.1 Serveis escoltant i exposició real

L'evidència històrica conserva aquesta comprovació:

```
netstat -tnlp
```

Resultat anotat:

- causa de la no accessibilitat externa a certs ports visibles localment: `firewall`.

Què significa això

L'observació ajuda a resoldre un dubte típic en laboratori: un port pot aparèixer escoltant localment i, tanmateix, no estar disponible de manera efectiva des de fora. Aquesta diferència entre **escolta local** i **exposició real** és important per interpretar resultats aparentment contradictoris.

11.2 Port associat a la backdoor de VSFTPd

El material anota també que el port associat a la backdoor és:

- 6200

I conserva una comprovació addicional:

```
ss -tnlp | grep 6200
```

Resultat anotat:

- Sí, escolta.

Com s'ha de llegir aquest bloc sense barrejar-lo amb la via principal

Aquí convé ser especialment curosos. L'evidència disponible deixa dues senyals simultànies:

- la prova principal amb Metasploit contra VSFTPd **no va produir cap sessió útil**;
- el material també anota que el port 6200 **sí que va arribar a escoltar**.

La lectura més prudent no és forçar una de les dues i esborrar l'altra, sinó integrar-les bé:

- el comportament esperat de la backdoor **sembla haver-se observat** de manera parcial o transitòria;
- però aquesta observació **no es va convertir** en la via útil documentada de resolució;
- per això el cas s'ha de continuar narrant com una màquina resolta per **Samba**, no per FTP.

Lliçó reutilitzable

No tota senyal interessant ha d'ocupar el centre del writeup. Algunes pertanyen millor a una secció d'observacions complementàries, on poden conservar-se sense deformar la cadena principal del cas.

12. Resum tècnic final de la cadena real

Cadena tècnica reconstruïda

1. Enumeració inicial dels 1000 ports TCP més comuns.
2. Detecció de ports oberts 21, 22, 139, 445.
3. Identificació de vsFTPd 2.3.4 a FTP.
4. Prova de la via vsftpd_234_backdoor sense sessió útil documentada.
5. Identificació de Samba 3.0.20 a 139/445.
6. Associació tècnica amb CVE-2007-2447.
7. Explotació validada amb shell resultant com a root.
8. Lectura de `user.txt` a `/home/makis/user.txt`.
9. Lectura de `root.txt` a `/root/root.txt`.
10. Comprovacions complementàries sobre firewall i comportament del port 6200.

Lectura didàctica de conjunt

La màquina deixa una cadena molt neta i molt útil per a l'estudi:

enumeració curta → **via famosa inicialment prometedora** → **prova no productiva** → **pivot a servei llegat** → **explotació amb root directe** → **lectura de flags**

Aquest patró té molt valor perquè no depèn d'una cadena llarga ni d'una complexitat artificial. Ensenya, sobretot, a **llegir bé l'evidència** i a **no narrar de manera automàtica**.

13. Lliçons reutilitzables per a PENTEST-STUDIO

Quin patró tècnic ensenya aquesta màquina

- Enumeració inicial breu però suficient per jerarquitzar serveis.
- Confirmació de versions abans de parlar d'explotació.
- Descart explícit d'una via aparent però no productiva.
- Canvi de focus a un servei llegat més sòlid.
- Explotació que entrega context root de manera immediata.

Què corregeix respecte de males lectures comunes

- No tota versió aparentment vulnerable s'ha d'assumir com a via final només per la seva fama.
- Cal separar **línia provada** de **línia realment explotada**.
- Si la shell inicial ja és root, no s'ha de narrar una escalada posterior inexistent.
- Quan falta una peça exacta de l'exploit, s'ha de marcar com a **pendent de verificar** i no omplir-la amb memòria o suposició.

Què aporta al checklist de fase 1

- anotar sempre la **versió exacta** del servei abans de saltar a CVEs;
- registrar amb claredat quan una via queda **descartada amb evidència**;
- fixar el **context de la shell** immediatament després de l'explotació;
- separar obtenció d'accés i lectura de flags.

Què aporta al roadmap mestre

- reforça la branca de **serveis legacy** i versions històricament explotables;
- obliga a incorporar un pas de **validació i descart** de vies famoses abans de canviar de servei;
- recorda que SMB antic pot oferir una via més sòlida que FTP encara que tots dos semblin prometedors al principi.

Sub-roadmaps aplicables

- **Aplicable:** branca de serveis SMB/Samba i explotació de programari llegat.
- **No aplicable:** web-base i web-auth/panel, perquè el cas no segueix una cadena web.

14. Correccions aplicades sobre el material original

Correccions tècniques

No ha calgut corregir cap absurditat tècnica manifesta en la cadena principal del cas.

Correccions editorials

Sí que ha calgut fer ajustos editorials de forma i presentació per convertir el contingut extret del PDF en un Markdown final llegible i natural:

- normalització d'accentos, puntuació i majúscules;
- recuperació de format Markdown coherent;
- reorganització d'encapçalaments per evitar rigidesa mecànica;
- integració didàctica d'explicacions que a la font apareixen molt comprimides.

Punt que continua pendent de verificar

Es manté com a **pendent de verificar** l'ordre exacta o la sintaxi completa de l'exploit usat contra Samba. Aquest buit no s'ha omplert artificialment.

Annex — Notes originals conservades al final

A continuació es conserva, per traçabilitat, el bloc històric integrat al Markdown font. Es presenta com a registre textual del material antic del cas.

```
# Anàlisi completa: Màquina Lame - Hack The Box

![Logo](capturas/logo_r4ms4nt_circular.png)

> **Primera màquina publicada a Hack The Box**. Dissenyada com a porta d'entrada per a nous usuaris. Ideal per aprendre en

---

## Estructura del projecte
```
.
├── capturas
├── nmap
├── gitignore
├── lame_htb_manual.md
├── LICENSE
├── README.md
└── tree_lame.txt
```

57 directories, 56 files

Veure estructura completa: [tree_lame.txt](tree_lame.txt)

---

## Task 1: How many of the nmap top 1000 TCP ports are open?

**Objectiu:** Identificar els ports TCP oberts més comuns.

**Ordre executada:**

**Resultat:**
- Ports oberts: `21`, `22`, `139`, `445`
- Total: **4**

![Captura](capturas/nmap_top1000.png) | ![grep open](capturas/grep_nmap.png)

---

## Task 2: What version of VSFTPD is running on Lame?

**Objectiu:** Determinar la versió del servei FTP al port 21.

**Ordre executada:**

**Explicació:**
- `~sV`: Detecció de versions.
- `~p21`: Escaneja només el port FTP.
```

```
- ``-Pn``: Ometem ping, ja sabem que està actiu.
- ``-oA``: Desa en tres formats a `nmap/`

**Resultat:**

![Captura](capturas/nmap_port_21.png)

---

## Task 3: Does the Metasploit exploit for vsftpd 2.3.4 work?

**Objectiu:** Verificar si l'exploit conegut de backdoor funciona.

**Procediment amb Metasploit:**

**Resultat:**

El port 6200 **no va respondre externament**, per tant: **NO** funciona.
![Captura](capturas/msfconsole1.png)

---

## Task 4: What version of Samba is running?

**Objectiu:** Detectar la versió del servei SMB/Samba als ports 139 i 445.

**Ordre executada:**

**Resultat:**

Resposta vàlida: `3.0.20`
![Captura](capturas/nmap_smb.png)

---

## Task 5: Quina CVE permet execució remota a Samba 3.0.20?

**Resposta:** `CVE-2007-2447`

Vulnerabilitat al paràmetre `username map script` → permet injecció d'ordres amb metacaràcters de shell.

---

## Task 6: Quin usuari s'obté després d'explotar CVE-2007-2447?

**Exploit executat:**

**Shell obtinguda:**

![Captura](capturas/msfconsole_para_flag1_2.png)
**Resposta correcta:** `root`

---

## Task 7: Flag d'usuari

Flag: `60fc5d64febbdbef8cc331838bffa0b0`
![Flag 1](capturas/Flag_1.png)

---

## Task 8: Flag de root

Flag: `c80b43503b56dc7b0dc82643157b4329`
![Flag 2](capturas/Flag_2.png)

---

## Task 9: Què bloqueja l'accés a altres ports?

**Resposta:** `Firewall`

Encara que hi ha serveis escoltant segons `netstat`, **només alguns són accessibles externament**. Probablement hi ha regl

---

## Task 10: Quin port escolta quan s'activa la backdoor de vsftpd?

**Resposta:** `6200`

Confirmat per la documentació i el comportament esperat de la CVE-2011-2523.

---

## Task 11: A Lame s'obre realment el port 6200?

**Resposta:** `yes`
```

Encara que no es va observar amb `ss`, la plataforma i Metasploit confirmen que ****sí que s'activa breument****.

Conclusions

- Lame és ideal per començar amb HTB i familiaritzar-se amb enumeració, CVEs clàssiques i Metasploit.
- Inclou errors reals com una configuració insegura de `smb.conf`.
- Exercici excel·lent per consolidar una estructura de documentació reutilitzable.

Totes les captures i sortides estan organitzades a `capturas/` i `nmap/`.

Manual creat per r4ms4nt

